

Threat Modelling with an Attack Tree

How an attacker could expose patient data in a shared health record system

Overview

This project is based on work I did for a university module on Cyber Security and Networks. The task was to build an attack tree for a new health record system. An attack tree shows the different ways an attacker could reach a goal. The goal sits at the top and each branch shows a route to it. Thinking like an attacker in this way helps show where defences are needed.

Disclaimer

For this portfolio version I changed the system to a fictional one called CareLink. The branches and attack steps are the ones I came up with in my original work.

Scenario

CareLink is a fictional digital health record. Patients use the CareLink app to book appointments, order prescriptions and view test results. GPs, hospitals, pharmacies and care services can all see the same record. This means one record holds a lot of sensitive data and many people can reach it, which makes it a big target.

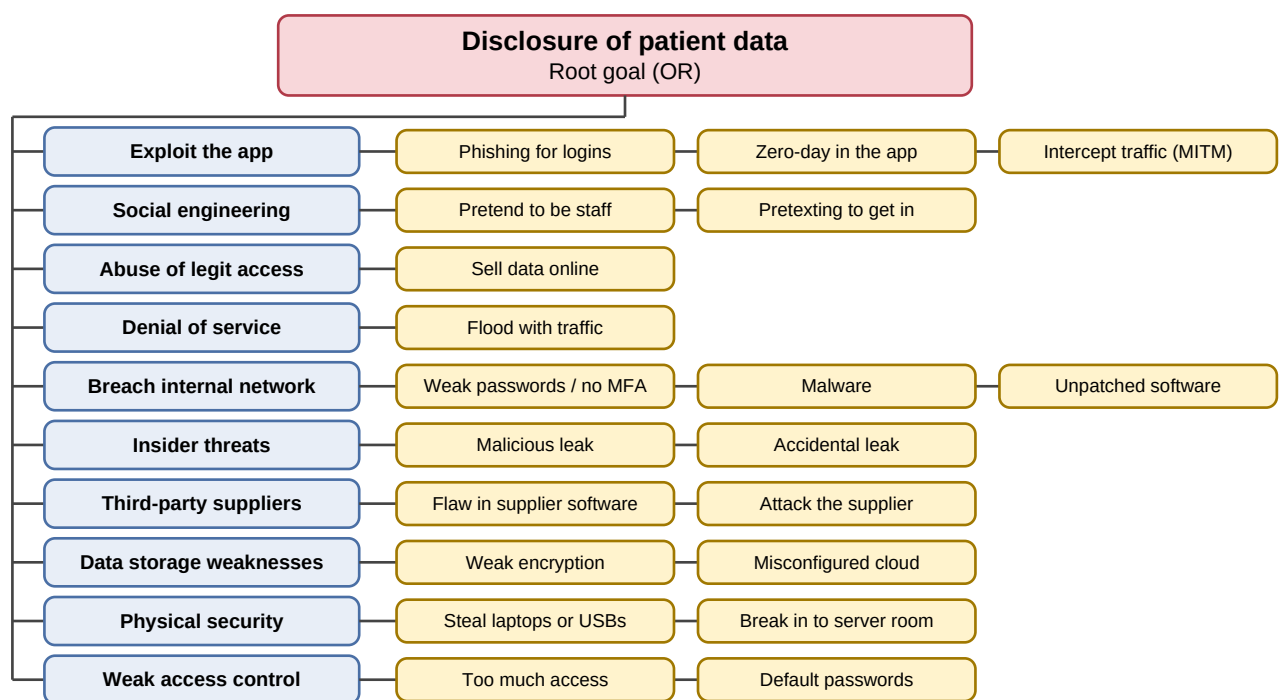


Figure 1. Attack tree with 10 branches and 20 leaf nodes

How to Read the Tree

- The root node at the top is the attacker's goal. Here it is the disclosure of patient data.
- The blue boxes are the main routes an attacker could take.
- The yellow boxes are leaf nodes. These are the actual steps an attacker would carry out.
- All the branches in my tree are OR nodes. This means any one of them could lead to the goal on its own.

Explaining the Tree

Exploit the app

The app is the main way patients and staff reach their records. Attackers could send fake emails pretending to be CareLink to steal logins. They could use a zero-day, which is a flaw the developers do not know about yet. They could also intercept data as it travels between the app and the servers.

Social engineering

This targets people instead of technology. An attacker could pretend to be a member of staff to trick others into giving out information. They could also make up a story, known as pretexting, to get into a building.

Abuse of legit access

Even staff who are allowed to see the data could misuse it, such as selling patient records online.

Denial of service

Flooding the system with traffic can knock it offline. While it is under strain, other weaknesses might be exposed.

Breach internal network

The internal network connects all the systems and databases. Attackers could get in through weak passwords or accounts without multi-factor authentication, malware such as spyware, or software that has not been patched.

Insider threats

An unhappy employee could leak data on purpose. A staff member who has not been trained could also leak data by accident.

Third-party suppliers

CareLink relies on outside companies for software and hardware. A flaw in their software could be used to get in, or the supplier itself could be hacked and used as a way in.

Data storage weaknesses

If data is not properly encrypted when stored or sent, attackers could read it. Records stored in the cloud could also be exposed if access settings are wrong.

Physical security

Laptops and USB drives holding data could be stolen. An attacker could also break into a building to reach the servers.

Weak access control

If users have more access than they need, an attacker who takes over their account can see more data. Default logins like "admin" are also easy to guess.

What I Would Change Now

Looking back at this work, there are a few things I would do differently. This section is extra and was not part of my original work.

- **Use AND nodes.** Many real attacks need more than one step. For example, phishing for a password only works if the account has no multi-factor authentication. Showing this with AND nodes would make the tree more realistic.
- **Rethink the denial of service branch.** Knocking a system offline does not expose data by itself. It would fit better as one step inside another branch.
- **Merge overlapping branches.** "Abuse of legit access" and "Insider threats" cover very similar ideas and could be one branch.
- **Rate each leaf node.** Adding how likely each step is, or how hard it would be, would show which risks to deal with first.
- **Link each branch to a defence.** The table below shows how I would protect against each one.

Branch	Main defences
Exploit the app	Phishing awareness, regular security testing, HTTPS everywhere
Social engineering	Staff training, ID checks, visitor sign-in
Abuse of legit access / Insider threats	Least privilege, access logging, regular access reviews
Denial of service	DDoS protection, rate limiting
Breach internal network	Multi-factor authentication, patching, endpoint protection
Third-party suppliers	Supplier security checks, limited supplier access
Data storage weaknesses	Encryption at rest and in transit, cloud configuration reviews
Physical security	Disk encryption on laptops, locked server rooms
Weak access control	Role-based access control, change default passwords

Conclusion

This attack tree shows that patient data can be exposed in many ways, not just through hacking. People, suppliers and physical security matter as much as the technology. Building the tree helped me think like an attacker, which is useful for working out where to put defences and what to look out for as a SOC analyst.